Toujours important d'être méticuleux dans nos actions, et de documenter prendre des screenshots et horodater de manière structurée notre pentest et évidemment la phase découverte d'application précédent ce que l'on va voir dans ce module

• Pour les grands environnement un bon workflow est d'exécuter nmap sur les ports les plus courants donc fournir la sortie à des outils comme "Eyewitness ou Aquatone qui vont prendre des captures d'écran de ces services puis pendant qu'on les analyse lancer un nmap sur les 10.000 ports les plus communs. NB. eyewitness est dispo via apt utilise la sortie XML de nmap

▲ Nous ne devons pas être négligent et commencer à attaquer les hôtes avant d'avoir achevé notre énumération complète

→ Méthodologie Solid et Reproductible
→ Organisation
→ Attention aux détailles
→ Communication, Reporting et Prise de note Approfondies

Voilà les Vrais clés de la Réussite

Les Systèmes de Gestion de Contenus (CMS):

1.0. WordPress Découverte et Énumération:

Comme j'ai pu le voir lors de la CDCA wordpress est le CMS le plus répandu faisant tourner des millions de site sa nature extensible par plugin et thèmes le rend aussi plus sujet à des vulnérabilités
Je renvoi au module WP-Attaque ou lors de la CDCA et ou j'ai effectuer une prise de notes détaillé
Pour identifier si un site tourne sous WP une des façons est de naviguer sur /robots.txt. Certains répertoires disallow pourront potentiellement nous renseigner
Comme nous l'avions vu il y a différent type d'utilisateur sur un site WP, seuls les administrateur nous donnerons souvent une RCE sur le serveur.
On peu faire un curl avec grep thèmes et plugins pour essayer d'identifier rapidement via le code source les thèmes et plugins installés

• RAPPELONS qu'il est HYPER important de ne pas commencer à exploiter directement la première vulnérabilité que nous voyons mais de faire une bonne et entière reconnaissance.

Selon la version du coeur de WP nous aurons diverses manière d'enumérer les utilisateurs (API rest, messages d'erreur, posts et commentaires, etc...)
Nous avons également l'excellent outil WP-Scan qui peu être utilisé pour automatiser ce processus d'énumération ⚠ il doit seulement rester un complément

1.1. Attaques Word-Press:

Hormis l'exploitation des vulnérabilités publiquement documentés lié aux version des plugins, thème ou du coeur de word-press détectés, on peu faire une attaque brute-force, pas discrète et souvent bloqué à cause du nombre important de requêtes.
Une fois l'accès administrateur obtenu on peu modifier une page du code source php en y injectant ainsi un webshell via un paramètre par exemple injectons dans la page 404.php le code suivant `system($_GET[interil]);` ensuite on peu exécuter les commandes sur la page cible ---/404.php?interil=whoami

Par ailleur le framework metasploit possède un module permettant d'automatiser cette exploitation: /exploit/unix/web_app/wp_admin_shell_upload. Mais comme toujours le faire soi-même plutôt que la facilité permet de savoir EXACTEMENT quelles modifications ont été apportés au système.